**IT GOVERNANCE**
Suggested Answers
July-August 2023

**Answer to the Question# 1(a):**

The major objective area for this programme is education and research.

The primary actors are BCC, BASIS, BCS, and Academia.

The programme is likely to benefit the nation through the expected deliverables and benefits. These are, more Industry ready people and increased opportunity for skilled IT workforce to get overseas jobs.

The short term and mid term goals of this action item are,

i. Initiate IPSAEP as a government programme in collaboration with industry and academia.
ii. Establish private entity for operations with ownership from the government, industry, and academia.

**Answer to the Question# 1(b):**

The major ethical, social, and political issues that information systems raise include the following five moral dimensions.

- **Information rights and obligations:** What information rights do individuals and organizations possess with respect to themselves? What can they protect?
- **Property rights and obligations:** How will traditional intellectual property rights be protected in a digital society in which tracing and accounting for ownership are difficult and ignoring such property rights is so easy?
- **Accountability and control:** Who can and will be held accountable and liable for the harm done to individual and collective information and property rights?
- **System quality:** What standards of data and system quality should we demand to protect individual rights and the safety of society?
- **Quality of life:** What values should be preserved in an information- and knowledge-based society? Which institutions should we protect from violation? Which cultural values and practices does the new information technology support?

**Answer to the Question# 2(a):**

Decision support systems use (i) analytical models, (ii) specialized databases, (iii) a decision maker's own insights and judgments, and (iv) an interactive, computer-based modeling process to support semi structured business decisions.

**Answer to the Question# 2(b):**

One of the major alternatives in MIS reporting is a report that is produced only when exceptional conditions occur. In other cases, reports are produced periodically but contain information only about these exceptional conditions. These are called "exception reports". An example can be, a credit manager can be provided with a report that contains only information on customers who have exceeded their credit limits.
Exception reporting reduces information overload instead of overwhelming decision makers with periodic detailed reports of business activity.

**Answer to the Question# 2(c):**

Data visualization systems represent complex data using interactive, three dimensional, graphical forms such as charts, graphs, and maps. DVS tools help users interactively sort, subdivide, combine, and organize data while the data are in their graphical form. This assistance helps users discover patterns, links, and anomalies in business or scientific data in an interactive knowledge discovery and decision support process.

Business applications like data mining typically use interactive graphs that let users drill down in real time and manipulate the underlying data of a business model to help clarify their meaning for business decision making.

**Answer to the Question# 2(d):**

The development of natural interfaces is considered a major area of AI applications and is essential to the natural use of computers by humans. For example, the development of natural languages and speech recognition are major thrusts of this area of AI. Being able to talk to computers and robots in conversational human languages and have them "understand" us as easily as we understand each other is a goal of AI research. This goal involves research and development in linguistics, psychology, computer science, and other disciplines.

Other natural interface research applications include the development of multisensory devices that use a variety of body movements to operate computers, which is related to the emerging application area of virtual reality. Virtual reality involves using multisensory human–computer interfaces that enable human users to experience computer-simulated objects, spaces, activities, and "worlds" as if they actually exist.

**Answer to the Question# 2(e):**

Conflicting blocks in a blockchain occur when two or more nodes in the network add different blocks to the chain at the same time. Across a network, there is a possibility of this happening and creating a fork in the chain. In this case, there is a 'consensus rule' that helps nodes figure out which is the block they should believe. In bitcoin, the rule is called the 'longest chain rule' – each node acknowledges the legitimacy of both contender blocks and the situation resolves when the next block is built on one of the contenders. The longer chain becomes part of the de-facto blockchain.

**Answer to the Question# 3(a):**

All organizations have bedrock, unassailable, unquestioned (by the members) assumptions that define their goals and products. Organizational culture encompasses this set of assumptions about what products the organization should produce, how it should produce them, where, and for whom. Generally, these cultural assumptions are taken totally for granted and are rarely publicly announced or discussed. Business processes—the actual way business firms produce value—are usually ensconced in the organization's culture. You can see organizational culture at work by looking around your university or college. Some bedrock assumptions of university life are that professors know more than students, the reason students attend college is to learn, and classes follow a regular schedule.

Organizational culture is a powerful unifying force that restrains political conflict and promotes common understanding, agreement on procedures, and common practices. If we all share the same basic cultural assumptions, agreement on other matters is more likely.

At the same time, organizational culture is a powerful restraint on change, especially technological change. Most organizations will do almost anything to avoid making changes in basic assumptions. Any technological change that threatens commonly held cultural assumptions usually meets a great deal of resistance. However, there are times when the only sensible way for a firm to move forward is to employ a new technology that directly opposes an existing organizational culture. When this occurs, the technology is often stalled while the culture slowly adjusts

**Answer to the Question# 3(b):**

Information systems can be used to enable a specific market focus and serve a narrow target market better than competitors. Information systems support this strategy by producing and analyzing data for finely tuned sales and marketing techniques. Information systems enable companies to analyze customer buying patterns, tastes, and preferences closely so that they efficiently pitch advertising and marketing campaigns to smaller and smaller target markets.

The data can come from a range of sources—credit card transactions, demographic data, purchase data from checkout counter scanners at supermarkets and retail stores, and data collected when people access and interact with websites. Sophisticated software tools find patterns in these large pools of data and infer rules from them to guide decision making. Analysis of such data drives one-to-one marketing that creates personal messages based on individualized preferences.

**Answer to the Question# 3(c):**

Both public- and private-sector organizations need a way to ensure that their IT functions support business strategies and objectives. And a formal IT governance program should be on the radar of any organization in any industry that needs to comply with regulations related to financial and technological accountability. However, implementing a comprehensive IT governance program requires a lot of time and effort. Where very small entities might practice only essential IT governance methods, the goal of larger and more regulated organizations should be a full-fledged IT governance program.

One of the most important paths to success is with executive buy-in. It is often recommended that a risk management committee with top-level sponsorships and business representation is formed. To ensure it's an effective program, it needs to be supported by a broad set of line of business leaders. It is also recommended to share results with the board or audit committee to develop real attention when items begin to get ignored. As with any significant project, one should always keep communication lines open between various parties, measure and monitor the progress of the implementation, and seek outside help if needed.

**Answer to the Question# 4(a):**

Wi-Fi networks are susceptible to hacking by eavesdroppers. Local area networks (LANs) using the 802.11 standard can be easily penetrated by outsiders armed with laptops, wireless cards, external antennae, and hacking software. Hackers use these tools to detect unprotected networks, monitor network traffic, and, in some cases, gain access to the Internet or to corporate networks.

Wi-Fi transmission technology was designed to make it easy for stations to find and hear one another. The service set identifiers (SSIDs) that identify the access points in a Wi-Fi network are broadcast multiple times and can be picked up fairly easily by intruders' sniffer programs. Wireless networks in many locations do not have basic protections against war driving, in which eavesdroppers drive by buildings or park outside and try to intercept wireless network traffic.

An intruder who has associated with an access point by using the correct SSID is capable of accessing other resources on the network. For example, the intruder could use the Windows operating system to determine which other users are connected to the network, access their computer hard drives, and open or copy their files.

To mitigate and address these security risks, the wifi network shall be configured with appropriate encryption protocol, strong password, mac address filtering, and proper network segmentation.

**Answer to the Question# 4(b):**

Web applications are vulnerable to SQL injection attacks. SQL injection attacks take advantage of vulnerabilities in poorly coded web application software to introduce malicious program code into a company's systems and networks. These vulnerabilities occur when a web application fails to validate properly or filter data a user enters on a web page, which might occur when ordering something online. An attacker uses this input validation error to send a rogue SQL query to the underlying database to access the database, plant malicious code, or access other systems on the network. Large web applications have hundreds of places for inputting user data, each of which creates an opportunity for an SQL injection attack.

**Answer to the Question# 4(c):**

Computer forensics is the scientific collection, examination, authentication, preservation, and analysis of data held on or retrieved from computer storage media in such a way that the information can be used as evidence in a court of law.
An effective electronic document retention policy ensures that electronic documents, e-mail, and other records are well organized, accessible, and neither retained too long nor discarded too soon. It also reflects an awareness of how to preserve potential evidence for computer forensics.
Computer forensics deals with the following problems.

- Recovering data from computers while preserving evidential integrity.
- Securely storing and handling recovered electronic data.
- Finding significant information in a large volume of electronic data.
- Presenting the information to a court of law.

**Answer to the Question# 4(d):**

Computer profiling and mistakes in the computer matching of personal data are other controversial threats to privacy. Individuals have been mistakenly arrested and jailed and people have been denied credit because their physical profiles or personal data have been used by profiling software to match them incorrectly or improperly with the wrong individuals.

Another threat is the unauthorized matching of computerized information about one extracted from the databases of sales transaction processing systems and sold to information brokers or other companies. A more recent threat is the unauthorized matching and sale of information about one collected from websites and newsgroups he/she visits. One is then subjected to a barrage of unsolicited promotional material and sales contacts as well as having his/her privacy violated.

**Answer to the Question# 4(e):**

Digital certificates are data files used to establish the identity of users and electronic assets for protection of online transactions. A digital certificate system uses a trusted third party, known as a certificate authority (CA), to validate a user's identity.

Public key infrastructure (PKI), the use of public key cryptography working with a CA, is now widely used in e-commerce. The CA verifies a digital certificate user's identity offline. This information is put into a CA server, which generates an encrypted digital certificate containing owner identification information and a copy of the owner's public key. The certificate authenticates that the public key belongs to the designated owner.

The CA makes its own public key available either in print or perhaps on the Internet. The recipient of an encrypted message uses the CA's public key to decode the digital certificate attached to the message, verifies it was issued by the CA, and then obtains the sender's public key and identification information contained in the certificate. By using this information, the recipient can send an encrypted reply. The digital certificate system would enable, for example, a credit card user and a merchant to validate that their digital certificates were issued by an authorized and trusted third party before they exchange data.

**Answer to the Question# 5(a):**

It is one thing to assess the degree to which a proposed system can work and quite another to evaluate whether the system will work. The human factors feasibility assessment focuses on the most important components of a successful system implementation: the managers and end users. No matter how elegant the technology, the system will not work if the end users and managers do not perceive it to be relevant and, therefore, do not support it. In this category, we assess the degree of resistance to the proposed system, the perceived role of the end users in the development process, the degree of change to the end users' working environment as a result of the new system, and the current state of human resources available to conduct the project and to manage and use the system on completion.

**Answer to the Question# 5(b):**

One of the primary activities that occur during the analysis phase is the construction of a logical model of the current system. The logical model can be thought of as a blueprint of the current system that displays only what the current system does without regard for how it does it. By constructing and analyzing a logical model of the current system, a systems analyst can more easily understand the various processes, functions, and data associated with the system without getting bogged down with all the issues surrounding the hardware or the software. Also, by creating a logical model, the various non computer components of a system can be incorporated, analyzed, and understood.

For example, in the physical version of a system, a person's inbox may be the location where new orders are stored until they have been entered into the computer. In the logical model, that inbox is treated just like a computer hard drive or other electronic storage media. In a logical sense, it is just another place to store data.

**Answer to the Question# 5(c):**

User interface design is the system component closest to business end users and the one they will most likely help design. The user interface design activity focuses on supporting the interactions between end users and their computer-based applications. Designers concentrate on the design of attractive and efficient forms of user input and output, such as easy-to-use Internet or intranet Web pages.

User interface design is frequently a prototyping process, where working models or prototypes of user interface methods are designed and modified several times with feedback from end users. The user interface design process produces detailed design specifications for information products such as display screens, interactive user/computer dialogues (including the sequence or flow of dialogue), audio responses, forms, documents, and reports.

**Answer to the Question# 5(d):**

Implementing new information systems for many organizations today frequently involves replacing a previous system and its software and databases. One of the most important implementation activities required when installing new software in such cases is called data conversion. For example, installing new software packages may require converting the data elements in databases that are affected by a new application into new data formats.

Other data conversion activities that are typically required include correcting incorrect data, filtering out unwanted data, consolidating data from several databases, and organizing data into new data subsets, such as databases, data marts, and data warehouses.

A good data conversion process is essential because improperly organized and formatted data are frequently reported to be one of the major causes of failures in implementing new systems.

The time chosen for data conversion is to be chosen depending on the estimated time needed. The important consideration here is not just the time necessary to effect the transfer but the preservation of the integrity of the current system data files during the process.

If the transfer is estimated to take several hours, the conversion can be carried out any day in the evening. If it is a couple of days, the weekends are the only option.

**Answer to the Question# 6(a):**

The following are steps a IS auditor would perform to determine an organization's level of compliance with external requirements:

- Identify those government or other relevant external requirements dealing with:
  - Electronic data, personal data, copyrights, e-commerce, e-signatures, etc.
  - Computer system practices and controls.
  - The manner in which computers, programs and data are stored.
  - The organization or the activities of information technology services.
  - IS audits.
- Document applicable laws and regulations.
- Assess whether the management of the organization and the IT function have considered the relevant external requirements in making plans and in setting policies, standards and procedures, as well as business application features.
- Review internal IT department/function/activity documents that address adherence to laws applicable to the industry.
- Determine adherence to established procedures that address these requirements.
- Determine if there are procedures in place to ensure contracts or agreements with external IT services providers reflect any legal requirements related to responsibilities.

**Answer to the Question# 6(b):**

Internal controls are normally composed of policies, procedures, practices and organizational structures that are implemented to reduce risk to an organization. Internal controls are developed to provide reasonable assurance to management that the organization's business objectives will be achieved and risk events will be prevented, or detected and corrected. Internal control activities and supporting processes are either manual or driven by automated computer information resources. Internal controls operate at all levels within an

organization to mitigate its exposures to risk that potentially could prevent it from achieving its business objectives. The board of directors and senior management are responsible for establishing the appropriate culture to facilitate an effective and efficient internal control system, and for continuously monitoring the effectiveness of the internal control system, although each individual within an organization must take part in this process.

There are two key aspects that internal controls should address: (i) what should be achieved and (ii) what should be avoided. Internal controls address business/operational objectives and should also address undesired events through prevention, detection and correction.

**Answer to the Question# 6(c):**

COBIT 5, developed by ISACA, provides a comprehensive framework that assists enterprises in achieving their objectives for the governance and management of enterprise IT (GEIT). Simply stated, it helps enterprises create optimal value from IT by maintaining a balance between realizing benefits and optimizing risk levels and resource use. COBIT 5 enables IT to be governed and managed in a holistic manner for the entire enterprise, taking in the full end-to-end business and IT functional areas of responsibility, considering the IT-related interests of internal and external stakeholders. COBIT 5 is generic and useful for enterprises of all sizes, whether commercial, not-for-profit or in the public sector.

COBIT 5 is based on five key principles for governance and management of enterprise IT,

- Principle 1: Meeting stakeholder needs.
- Principle 2: Covering the enterprise end-to-end.
- Principle 3: Applying a single, integrated framework.
- Principle 4: Enabling a holistic approach.
- Principle 5: Separating governance from management.

**Answer to the Question# 6(d):**

The purpose of a financial audit is to assess the accuracy of financial reporting. A financial audit will often involve detailed, substantive testing, although increasingly, auditors are placing more emphasis on a risk- and control-based audit approach. This kind of audit relates to financial information integrity and reliability. Whereas an operational audit is designed to evaluate the internal control structure in a given process or area. IS audits of application controls or logical security systems are some examples of operational audits.

An integrated audit combines financial and operational audit steps. An integrated audit is also performed to assess the overall objectives within an organization, related to financial information and assets' safeguarding, efficiency and compliance. An integrated audit can be performed by external or internal auditors and would include compliance tests of internal controls and substantive audit steps.

**Answer to the Question# 6(e):**

A risk-based audit approach is usually adapted to develop and improve the continuous audit process. This approach is used to assess risk and to assist an IS auditor in making the decision to perform either compliance testing or substantive testing. It is important to stress that the risk-based audit approach efficiently assists the auditor in determining the nature and extent of testing.

Within this concept, inherent risk, control risk or detection risk should not be of major concern, despite some weaknesses. In a risk-based audit approach, IS auditors are not just relying on risk. They also are relying on internal and operational controls as well as knowledge of the company or the business. This type of risk assessment decision can help relate the cost-benefit analysis of the control to the known risk, allowing practical choices.

---The End---